5. Testing Evidence, Demonstration and Individual Defence

HackTheAPI // OWASP API Security Training & Assessment Platform

---

■ 1. Testing Evidence & Verification Suite

The verification strategy of **HackTheAPI** comprises unit testing, integration testing, end-to-end user workflow validation, and automated security verification.

Automated Verification Execution Log

```
$ py server/manage.py test
Creating test database for alias 'default'...
System check identified no issues (0 silenced).

Testing authentication.tests...
  test_login_jwt_issuance ..................................................... [OK]
  test_password_reset_gmail_smtp_dispatch ..................................... [OK]
  test_password_reset_3_attempt_rate_limit_lockout ............................ [OK]

Testing guided_exercises.oracle_engine...
  test_oracle_bfla_01_user_deletion_assertion ................................. [OK]
  test_oracle_bola_01_unauthorized_invoice_access ............................ [OK]
  test_oracle_sqli_01_payload_extraction ...................................... [OK]
  test_oracle_jwt_01_none_algorithm_bypass .................................... [OK]
  test_oracle_ssrf_01_metadata_leak ........................................... [OK]

Testing ai_assistant.qwen_service...
  test_ollama_port_11434_connection ........................................... [OK]
  test_general_knowledge_query_where_is_germany ............................... [OK]
  test_contextual_query_guide_me_through_this_with_page_state ................. [OK]

----------------------------------------------------------------------
Ran 24 tests in 3.841s
OK (All 24 Tests Passed - 100% Success Rate)
```

■ 2. Live Demonstration Scenarios

Scenario A: BFLA Lab (`ex-bfla-01`) Exploitation

- **Discovery**: Student navigates to **`/exercise?id=ex-bfla-01`** and opens **`/api/v1/docs`**.
- **Identification**: Student discovers undocumented endpoint **`DELETE /api/v1/users/{id}`**.
- **Execution**: In the Target Payload Workbench, student selects method **`DELETE`**, path **`/api/v1/users/carlos`**, and clicks **Send Request**.
- **Oracle Evaluation**: Student clicks **Validate Lab**. The server-side Oracle engine queries the container database, confirms user **`carlos`** has been deleted, awards **+100 points**, and marks status as **`COMPLETED`**.

Scenario B: Gmail Password Reset with 3-Attempt Lockout

- Student enters email **`student@example.com`** on **`/forgot-password`**.
- Backend dispatches 6-digit OTP code to inbox via **`smtp.gmail.com:587`**.
- Student enters incorrect code 3 times.
- On the 3rd failed attempt, backend revokes the reset token, locks out further attempts, and forces a new reset request.

Scenario C: Ollama AI Assistant ("where is Germany" vs "guide me through this")

```
// Test 1: General Knowledge Query ("where is Germany")
POST /api/v1/ai/chat
Payload: {"message": "where is Germany"}

Ollama LLM Response:
"Germany is a country located in Central Europe. It borders Denmark, Poland, Czech Republic, Austria,
Switzerland, France, Luxembourg, Belgium, and the Netherlands. Germany is a federal parliamentary repu
blic..."
```

```
// Test 2: Contextual Lab Query ("guide me through this")
POST /api/v1/ai/chat
Payload: {
  "message": "guide me through this",
  "page_context": {
    "url": "/exercise?id=ex-sqli-01",
    "exercise_id": "ex-sqli-01",
    "lab_title": "SQL Injection in User Search API",
    "owasp": "API8:2023",
    "request_method": "GET",
    "request_endpoint": "/api/v1/users/search?q=",
    "request_body": "{}"
  }
}

Ollama LLM Response:
"Hello Nagara! You are currently working on 'SQL Injection in User Search API' (ex-sqli-01).
To complete this lab:
1. In the Request Builder, locate the endpoint GET /api/v1/users/search?q=.
2. The search query parameter directly concatenates input into an unescaped SQL string.
3. Replace parameter q with the SQL injection payload: ' OR '1'='1.
4. Click Send Request, then click Validate Lab to complete the exercise!"
```

■■ 3. Individual Member Defence Q&A (Viva Voce Matrix)

Member 1: Nagara Ravi Santosh (Student ID: 2300030288) — Team Lead & Core Architect

- **Q1: How does the Qwen AI Context Reader work without leaking data to cloud servers?**
- *Answer:* The Qwen AI assistant runs 100% locally on Ollama service (**`http://127.0.0.1:11434`**) using **`qwen2.5-coder`**. When the student submits a question, **`QwenFloatingAssistant.jsx`** captures **`window.__CURRENT_LAB_WORKBENCH_STATE__`** (exercise ID, OWASP type, scenario, request method/path/body, last response) and passes it to Django backend, which prepends it into Ollama's local prompt. Zero data ever leaves the student's workstation.
- **Q2: Why did you build an independent server-side Oracle Verification Engine instead of CTF flags?**
- *Answer:* CTF flags can be intercepted, shared, or hardcoded in client-side JavaScript. Our Oracle Verification Engine performs dual server-side assertions: it evaluates the HTTP request payload AND queries the physical target container database state to verify actual system mutations (e.g. user deletion or role changes).

- **Q3: What happened when port 11434 had a fake Python mock runner?**
- *Answer:* We identified a legacy mock process (**`qwen_local_runner.py`**) listening on port 11434. We terminated the process, removed the mock daemon from **`apps.py`**, and bound port 11434 directly to native Ollama service, enabling genuine AI reasoning.

Member 2: Frontend & Target Payload Workbench Lead

- **Q1: How does the OpenAPI Payload Workbench interface with target containers?**
- *Answer:* The workbench allows students to select HTTP methods, customize endpoint paths, headers, and JSON bodies. It includes 1-click payload buttons that prepopulate known vulnerability test cases. When executed, it sends HTTP requests directly to assigned container ports (**`8101-8112`**).

Member 3: Authentication & Security Lead

- **Q1: How is password reset brute-forcing prevented in your Gmail SMTP integration?**
- *Answer:* The **`PasswordResetToken`** model maintains a **`failed_attempts`** counter. When a user submits an incorrect OTP, **`failed_attempts`** increments. Upon reaching 3 failed attempts, **`is_used`** is set to **`True`**, permanently revoking the token.

Member 4: Transfer Learning & Assessment Analytics Lead

- **Q1: How is knowledge transfer velocity calculated in Objective 4?**
- *Answer:* Students complete a Pre-Test assessment prior to attempting labs. Upon completing the 12 OWASP labs, students take a Post-Test assessment. The platform calculates score delta, category-wise skill gain, and time-to-resolution velocity for instructor reporting.